

Circular S-04 — Identity and Access Management — Zero Trust Implementation Mandate

Reference:	FRA/S/2025/004	Issue Date:	01 Apr 2025
Effective Date:	01 Sep 2025	Response Deadline:	31 Jul 2025
Issuing Authority:	Financial Regulatory Authority	Classification:	MANDATORY

1. Zero Trust Mandate

All regulated firms must implement Zero Trust Architecture (ZTA) for access to critical systems by 1 Sep 2025. ZTA requires continuous verification of identity and device posture — implicit trust based on network location is prohibited.

2. Privileged Access

Privileged Access Management (PAM) controls are mandatory for all administrator accounts. Just-in-time access provisioning must be implemented. All privileged sessions must be recorded and retained for 1 year. Shared administrator accounts are prohibited.

3. MFA Requirements

Multi-Factor Authentication is mandatory for: all remote access; all cloud management consoles; all access to systems containing client data; all email platforms. SMS-based OTP is no longer acceptable as a second factor — TOTP or hardware tokens required.

4. Access Reviews

Quarterly access reviews are mandatory for all privileged accounts and systems containing client data. Dormant accounts (inactive >30 days) must be automatically disabled. Annual recertification of all user access rights is required.